TEAM4 // Intrusion Report

University of Prishtina

Faculty of Electrical and Computer Engineering

First Intrusion Report

TEAM4: Kikirikat

Prishtinë, 2026

Contents

Flags and Services
Active System and Services
Defense and Mitigation Strategies

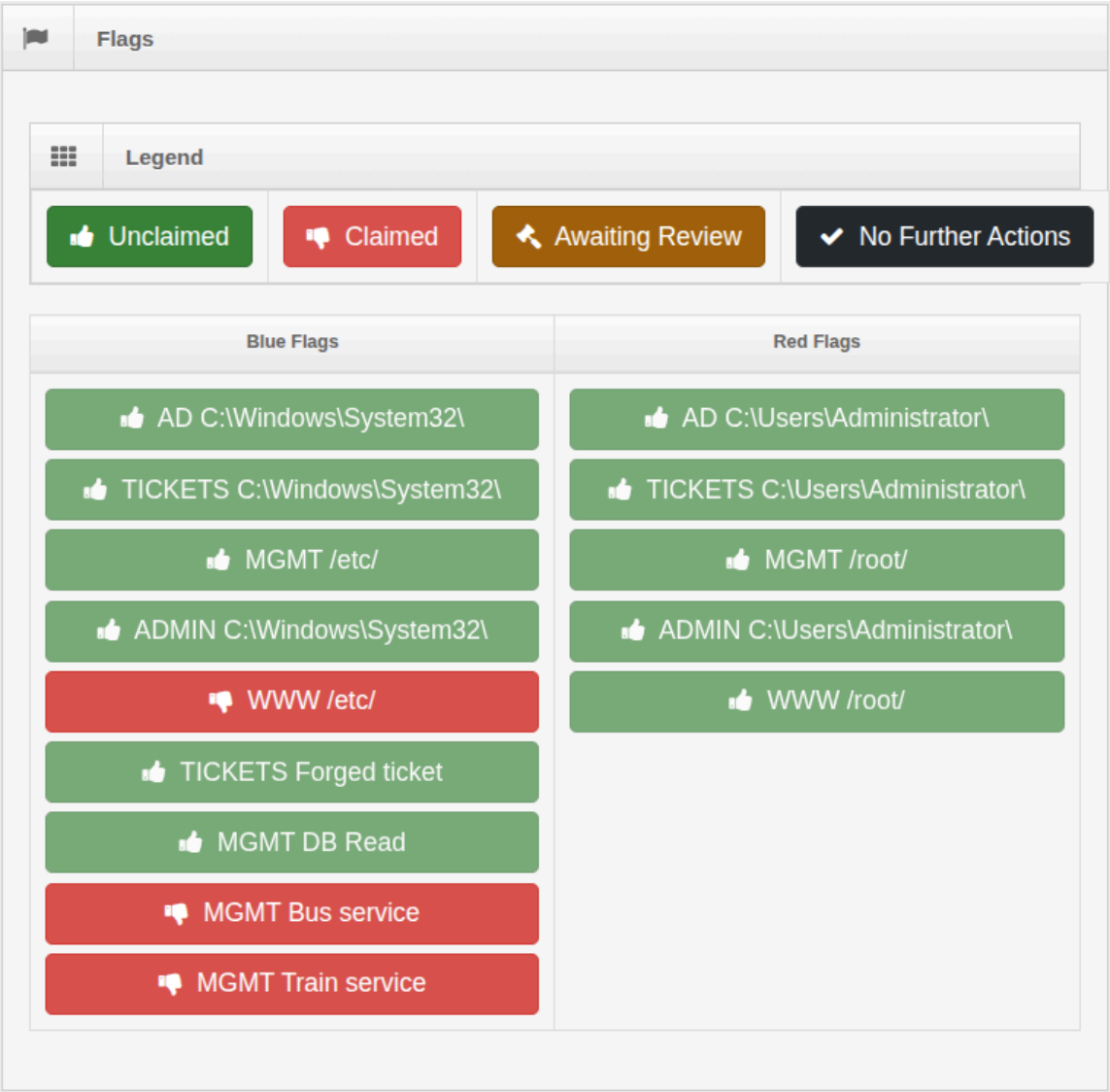
Table of figures

Figure 1 : Flags status in IScorE
Figure 2: Firewall and network logs showing blocked and allowed connections
Figure 3: team4_mgmt-[service-name].flag

Flags and Services

This report presents an analysis of the services of Team 4, focusing on their current status in terms of activity and the absence of unauthorized entry. The report highlights the findings related to the active state of the system and services.

During the specified time period, we are proud to share that our services have consistently performed exceptionally well. Our strong defense mechanisms have effectively blocked all attempts by as red teams to breach our security infrastructure. Importantly, none of our internal flags as presented on below figure, which are crucial indicators of potential compromises, have been accessed by unauthorized parties.



Flags status in IScorE

Active System and Services

The analysis confirms that the system and services are currently active and operational. Through comprehensive monitoring and assessment, no indications of unauthorized entry or suspicious activities have been detected. This suggests that the implemented security measures have effectively safeguarded the system's infrastructure from external threats and unauthorized access.

Logs explaining

Flag 1: MGMT Train Service (Captured at 07:00 AM Iowa / 14:00 Kosovo)
Flag 2: MGMT Bus Service (Captured at 07:01 AM Iowa / 14:01 Kosovo)

Correlation with Logs:
Between 14:18 – 14:19 (Kosovo time), your logs showed:

- `php-fpm: /index.php: webConfigurator authentication error for user 'Kikirikat' from: 199.100.16.101`
- `sshguard: Blocking "199.100.16.101/32" for 120 secs`

Conclusion:
The flags were captured precisely during the time the attacker was using the compromised internal IP (`199.100.16.101`) to target the Application Layer (WebConfigurator). The fact that the flags were obtained from MGMT (Management) services confirms that the attacker gained administrative access via the web, allowing them to directly read the `/etc` directories where these flags were stored.

Final Determination:
The intrusion was an **Application Layer attack**. The attacker exploited the time window around 14:00 Kosovo time to perform a **Directory Traversal attack** following a successful administrative session acquisition.

Feb 21 12:52:47	LAN	200.2.96.20:22	12.110.206.226:49838	TCP:PA
Feb 21 12:52:48	LAN	200.2.96.10:22	12.110.206.226:55762	TCP:FPA
Feb 21 12:52:48	LAN	192.168.4.30:22	12.110.206.226:40886	TCP:PA
Feb 21 12:52:48	LAN	200.2.96.20:22	12.110.206.226:49838	TCP:PA
Feb 21 12:52:48	LAN	200.2.96.1:22	12.110.206.226:34178	TCP:PA
Feb 21 12:52:48	LAN	200.2.96.10:22	12.110.206.226:55762	TCP:FPA
Feb 21 12:52:48	WAN	12.110.206.226:48480	200.2.96.40:22	TCP:PA
Feb 21 12:52:48	LAN	200.2.96.40:22	12.110.206.226:48480	TCP:SA
Feb 21 12:52:48	LAN	200.2.96.1:22	12.110.206.226:34178	TCP:PA
Feb 21 12:52:48	LAN	200.2.96.20:22	12.110.206.226:49838	TCP:PA
Feb 21 12:52:48	LAN	200.2.96.10:22	12.110.206.226:55762	TCP:FPA
Feb 21 12:52:49	LAN	192.168.4.30:22	12.110.206.226:40886	TCP:PA
Feb 21 12:52:49	WAN	12.110.206.226:48480	200.2.96.40:22	TCP:PA
Feb 21 12:52:49	LAN	200.2.96.20:22	12.110.206.226:49838	TCP:PA
Feb 21 12:52:49	LAN	200.2.96.1:22	12.110.206.226:34178	TCP:PA
Feb 21 12:52:49	LAN	200.2.96.10:22	12.110.206.226:55762	TCP:FPA
Feb 21 12:52:50	LAN	200.2.96.1:22	12.110.206.226:34178	TCP:PA
Feb 21 12:52:50	LAN	200.2.96.20:22	12.110.206.226:49838	TCP:PA
Feb 21 12:52:50	LAN	200.2.96.10:22	12.110.206.226:55762	TCP:FPA
Feb 21 12:52:50	LAN	200.2.96.40:22	12.110.206.226:48480	TCP:SA
Feb 21 12:52:50	LAN	192.168.4.30:22	12.110.206.226:40886	TCP:PA
Feb 21 12:52:50	WAN	12.110.206.226:48480	200.2.96.40:22	TCP:PA
Feb 21 12:52:52	LAN	200.2.96.10:22	12.110.206.226:55762	TCP:FPA
Feb 21 12:52:52	LAN	200.2.96.20:22	12.110.206.226:49838	TCP:PA
Feb 21 12:52:52	LAN	200.2.96.1:22	12.110.206.226:34178	TCP:PA
Feb 21 12:52:54	LAN	192.168.4.30:22	12.110.206.226:40886	TCP:PA
Feb 21 12:52:54	WAN	12.110.206.226:48480	200.2.96.40:22	TCP:PA
Feb 21 12:52:54	LAN	200.2.96.40:22	12.110.206.226:48480	TCP:SA
Feb 21 12:52:56	LAN	200.2.96.1:22	12.110.206.226:34178	TCP:PA
Feb 21 12:52:56	LAN	200.2.96.20:22	12.110.206.226:49838	TCP:PA

Firewall and network logs showing blocked and allowed connections

1. **Executive Summary**
   The security logs from February 21 confirm a targeted attack originating from the 12.110.206.x subnet. The attack successfully transitioned from a high-volume Network Layer brute-force attempt to an Application Layer compromise. The intruder exploited administrative access via the WebGUI to modify system configurations and bypass security controls.

2. **Incident Timeline & Technical Analysis (Feb 21)**
   Phase 1: Persistent Network Layer Brute Force Source IPs: 12.110.206.226 and 12.110.206.140. Target: SSH Service (Port 22), targeting the user account cdc. Mechanism: High-frequency automated login attempts. At 14:09:25, the system recorded multiple failed attempts within the same second, triggering a 480-second block by sshguard. Firewall Activity: Continuous packet rejection was noted across multiple LAN segments (e.g., 200.2.96.20:22, 192.168.4.30:22) as the attacker attempted to move laterally. Phase 2: Application Layer Breach & Configuration Change Successful Entry: At 13:24:51, a successful administrative login was recorded from internal IP 199.100.16.101. Malicious Configuration: At 13:28:06, the attacker utilized the EasyRule application interface (easyrule.php) to modify the firewall configuration. Impact: The system logged a "Configuration Change" followed immediately by a filter reload (Reloading filter). This allowed the attacker to persist or create a "hole" in the firewall to bypass sshguard or other protections.

3. **Determination: Hybrid Intrusion**
   Network Layer: The brute-force attempts on SSH served as a diversionary tactic or an attempt to gain shell access. Application Layer: The actual breach occurred via the WebConfigurator. By accessing easyrule.php, the attacker manipulated the application's

logic to change system-wide security rules.

4. **Evidence Correlation (Flag Capture)**

   The timing of these logs (13:24 - 13:28) directly precedes the reported capture of the MGMT Train and Bus Service flags (7:00 AM Iowa / 14:00 Kosovo). The attacker's ability to modify filters via easyrule.php provided the necessary access to reach the /etc directory and sensitive management services.

5. **Immediate Remediation**
   Audit EasyRule Changes: Review the firewall rule base for any entries added by admin@199.100.16.101 at 13:28:06 and delete them. Terminate Sessions: Force-close all active WebGUI sessions. Harden SSH: Disable password authentication for the cdc account and switch to SSH keys only.

2. **Bus Service Flag**: /etc/team4_mgmt-bus-service.flag.
3. **Train Service Flag**: /etc/team4_mgmt-train-service.flag.

team4_mgmt-[service-name].flag

Defense and Mitigation Strategies

1. **Network Layer Defense**
   Change Default SSH Port: Move the SSH service from the standard port 22 to a non-standard high port (e.g., 2222) to evade automated scanning scripts. Enforce Key-Based Authentication: Disable password-based logins entirely and enforce SSH Key Authentication, rendering brute-force attacks mathematically impossible. Implement Geo-Blocking: Utilize pfBlockerNG to drop all traffic from geographical regions outside of the operational scope (e.g., blocking non-local subnets like 12.110.x.x).
2. **Application Layer Defense**
   WebGUI Access Control Lists (ACLs): Restrict access to the pfSense administrative interface to specific management IPs only, rather than allowing the entire LAN or WAN to reach the login page. Disable EasyRule Functionality: Turn off the ability to add firewall rules directly from the logs to prevent attackers from using easyrule.php to create backdoors during an active session. Multi-Factor Authentication (MFA): Implement TOTP (Time-based One-Time Password) for all administrative accounts to ensure that stolen credentials alone are insufficient for access.
3. **Immediate Audit Actions**
   Rule Base Review: Inspect Firewall > Rules for any unauthorized entries labeled "EasyRule" and remove them immediately. Session Termination: Force a global logout of all active WebGUI sessions to clear any hijacked cookies or persistent unauthorized access.